BIS POSTGRADUATE PROJECT
(1CYB1 2024-25)
Final Deliverable

Group 3

Securing the Smart Future: A IoT Risk Management Framework

List of Authors:

STUDENT ID	STUDENT NAME	EMAIL
24233256	Nishita Sunil Parija	nishitaparija@gmail.com
24235884	Vedangi Vilas Padyal	vedangi6.work@gmail.com
24236493	Sanjana Hiremath	sanjanahiremath02@gmail.com

In submitting this work, we confirm that it is entirely our own. We acknowledge that any or all of our group may be invited to an online interview if there is any concern concerning the integrity of our submission, and we are aware that any breach will be subject to the University's Procedures for dealing with breaches of Exam Regulations. We are aware of what the University of Galway's plagiarism policy entails and are familiar with university policies relevant to this deliverable.

Select here if you wish your report to be included in the online book: Yes ☑ No

Name for the framework:

VECTOR: **V**ulnerability **E**limination & **C**ontrol **T**hrough **O**perational **R**emediation

Preamble

The Internet of Things (IoT) industry has revolutionised modern life with its recent advancement, particularly in consumer environments such as smart homes and wearables. While this transformation enhances convenience and real-time decision-making, it also introduces significant cybersecurity challenges. IoT devices, especially consumer ones, are often deployed without much protection at the firmware, protocol, and data storage levels.

This project proposes the VECTOR framework aimed at addressing core IoT vulnerabilities associated with the protocols used in data transmission. VECTOR integrates preventative, detective, and corrective controls across the device lifecycle, emphasising secure design, protocol hardening, and data protection. It also incorporates AI-assisted detection, secure boot mechanisms, cryptographic protocols, and policy-aligned compliance features.

The project emphasises the importance of coordination among IoT manufacturers, security professionals, and regulators to standardise controls and align with international standards such as ISO/IEC 27000 series, NIST SP 800 series, and GDPR, among others. The goal is to achieve a secure-by-design ecosystem IoT to reduce attack surfaces across protocol layers.

Chosen Setting

This framework revolves around consumer-grade IoT environments like smart home networks, personal wearables, and health monitors, among others. However, the emphasis is placed on the security of core communication protocols like Wi-Fi, Bluetooth/BLE, MQTT, Zigbee/Z-Wave, and NFC/RFID, which remain overly vulnerable to exploitation despite the absence of layered security controls.

Rationale for Selection

Consumer IoT devices process extremely sensitive data and interact with mobile apps, cloud services, and third-party providers. However, many of such devices operate on insecure or legacy protocols and are therefore easy targets for attackers. Consumer IoT does not have the organised patching, secure authentication, or encrypted storage that exists in enterprise or industrial IoT. A dedicated protocol-specific risk management framework like VECTOR is needed to address these gaps and ensure stronger baseline security across the IoT lifecycle.

Executive Summary

This report introduces the VECTOR framework, a protocol-specific cybersecurity risk management model for consumer IoT devices. Existing standards such as NIST, ISO/IEC 27001, ETSI EN 303 645, and the IoT Security Maturity Model are reviewed, and their limitations in protocol-level vulnerability mitigation are analysed. VECTOR addresses these gaps by offering

a layered, actionable framework focused on secure manufacturing, encrypted communications, lifecycle protection, and testing. The model also includes threat modelling, real-world risk validation using appropriate tools, and compliance mapping to EU directives.

1. Introduction

1.1 Why do we need a new framework?

The IoT industry has evolved and expanded vigorously across various domains from smart home thermostats and voice assistants to connected fitness bands and smart appliances. However, IoT devices still rely on lightweight protocols for communication and minimal computing resources, often at the expense of security. These devices are often deployed without encryption, use hardcoded credentials, or fail to offer secure updates. Traditional IoT security models do not address the issues associated with consumer IoT ecosystems, particularly protocol-level threats. These gaps highlight the need for a tailored framework capable of addressing the full attack surface specific to consumer IoT.

1.2 Objective of VECTOR

The framework aims to address the gaps in the existing frameworks and standards around consumer IoT devices and thus enhance their security by addressing vulnerabilities within their communication protocols. Moreover, the framework also addresses the possible risk vectors associated with the IoT devices in their manufacturing, and data handling processes.

1.3 What will VECTOR do?

VECTOR is primarily focused on the MQTT, CoAP, HTTP, Bluetooth/BLE, Zigbee/Z-Wave, and NFC/RFID protocols, used in the transmission of data around consumer IoT devices. However, it extends its attention towards legacy IoT communication systems and redundant devices still operating with dated firmware, which may lack encrypted communication and are improperly decommissioned, risking data leakage or unauthorised reuse.

VECTOR focuses on practical, testable, and standards-aligned controls that can be adopted by IoT device manufacturers to improve baseline security.

1.4 The Approach for Designing VECTOR

VECTOR does not undermine the existing standards and frameworks designed for and around IoT ecosystems. It simply indents to fill the gaps that exist within them. The framework was designed as a four-step process. The first step involved a detailed review of existing IoT security frameworks such as NIST, ISO/IEC, DORA, and ETSI, among others, to identify gaps specifically in protocol-level and data-layer protections. The second step follows a structured threat analysis, conducted on popular communication protocols commonly used in consumer

IoT environments to better understand potential vulnerabilities. The third step focused on creating a risk identification, registration and assessment model that leveraged real-world tools, namely, Binwalk, Bettercap, and Hydra to simulate and address actual attack scenarios. In the fourth step, the framework was designed as a layered security model that maps controls across manufacturing, protocol, and data storage phases, for securing each stage. Throughout its development, VECTOR emphasised alignment with key compliance standards including NIS2, ISO/IEC 27030, and the Cyber Resilience Act to ensure that the framework not only enhances technical security but also supports policy readiness and regulatory compliance.

2. Risk Identification

2.1 How are they identified?

The use of lightweight and insecure communications protocols has especially endangered consumer IoT devices. Most protocols convey plaintext messages or authentication schemes. Bluetooth excludes mutual authentication, MQTT does not always include necessary TLS, and Zigbee/Z-Wave are tormented by weak key management. Moreover, these threats would also come from unsecured firmware updates, dated Wi-Fi settings, and weak cryptographic protections in technologies like NFC/RFID. These vulnerabilities expose devices to numerous attacks like, but not limited to, man-in-the-middle (MitM), replay attacks, command hijacking, denial-of-service (DoS), device cloning, and brute-force attacks. The environment becomes progressively suspicious due to the absence of dynamic vulnerability scanning, real-time monitoring of attacks, and secure cloud integrations as well as the presence of unpatched firmware and legacy protocols, cumulatively leading to a large attack surface.

2.1.1 Risk Identification Across Frameworks

The frameworks that are already utilised across the IoT space utilise ordered methodologies for IoT cybersecurity risk identification, yet the ontological gaps persist.

NIST SP 800-183 evaluates IoT ecosystem risk through rigorous examination of the device heterogeneity and connectivity but fails to offer adequately granular advice and taxonomical categorisation to counter emerging threats like edge computing and AI-driven attack vectors. NIST SP 800-53, extending the comprehensive SP 800-30 methodology, accurately taxonomies adversarial and non-adversarial threats but inefficiently models the co-alignment of operational technology and IoT's dynamic architecture. ISO/IEC 27001, follows ISO 27005's asset-focused risk assessment standards, with big asset inventory and impact quantification, but is still handicapped by the static, asset-concentric approach that cannot account for the churn of IoT-specific threats. ETSI EN 303 645 deals with consumer IoT vulnerabilities specifically, default passwords and authentication vulnerability-with methodological accuracy but not entirely to industrial IoT (IIoT) and broader ecosystem threats. IIC Security Maturity Model (SMM) assesses risks in six security areas using maturity indicators, but its conceptual, self-contained paradigm is not combined with normative threat taxonomies and mechanisms for identifying emergent zero-day vulnerabilities or rapidly changing attack patterns in ephemeral IoT environments. (SHACKELFORD, RUSSELL and HAUT, 2018)

2.2 Threat Identification

Existing IoT frameworks like NIST SP 800-53, ISO/IEC 27001, and ETSI EN 303 645 fail to effectively mitigate existing threats against wireless protocols, physical layers, and cloud infrastructure.

The attack scenario within consumer IoT ecosystems is rapidly evolving with the extensive application of lightweight communication protocols and the lack of standardised security regulations. Update procedures for the firmware also represent a significant threat vector because an insecure boot and digital signature verification render devices susceptible to malicious firmware injection. In addition, cloud and API integrations introduce shadows data exposure, token misuse, and credential hijacking threats to risks that are not fully covered by existing standards like ISO/IEC 27002 and ETSI EN 303 645, which are likely lacking controls for tokenisation, rate limiting, and secure API management, thus the urgent need for protocol-aware threat detection capable of resolving the new and evolving challenges of today's IoT ecosystem.

2.3 Vulnerability Assessment

There are vulnerabilities in all systems that can go unnoticed. There can be old firmware, default vulnerability, or backdoors in IoT devices. The simple way to assess these vulnerabilities is by scanning them through a set of tools. Binwalk and QEMU tools can be utilised to discover hardcoded credentials, backdoors, or insecure defaults, insecure authentication can be inspected with brute-force attack simulation using Hydra and Hasheat to test password policy and logon security as per access control practices. Insecure encryption schemes are tested through OpenSSL to experiment with TLS/SSL configurations such as TLS 1.3 and forward secrecy, thereby providing safe communication platforms. Finally, the vulnerability of misuse of protocols such as man-in-the-middle and replay attacks can be investigated by employing Bettercap and Zigbee sniffers to capture unsecured traffic patterns. Such routines overall increase IoT device security. Current frameworks lack prescriptive methods for IoT-specific vulnerability testing. NIST SP 800-53 and ISO/IEC 27001 do not mandate firmware forensic toolkits like Binwalk, QEMU or Hydra, which allow weak credentials and hardcoded passwords to escape detection. Test blind spots for protocol-specific tests are evident in the lack of OpenSSL scanning for TLS/SSL configurations (IIC SMM) and MITM sniffing tools like Bettercap in Zigbee/Z-Wave testing (NIST SP 800-183).

ETSI EN 303 645 does not specify encryption protocol validation procedures, while all frameworks rely on time-tabled audits rather than in-time dynamic scanning significant limitation considering IoT's dynamic changing threat landscape. The deficiencies weaken the capability to identify vulnerabilities in authentication mechanisms, encrypted data communications, and firmware integrity. (Hamdani, 2021)

3. Risk Assessment

3.1 Risk Analysis & Risk Register

3.1.1 Risk Analysis

Standards such as NIST Special Publication 800-183 and 800-53, ISO/IEC 27001 and 27002, ETSI EN 303 645 (European IoT Security Standard), and the Industrial Internet Consortium's (IIC) IoT Security Maturity Model (SMM) provide specific guidelines for registering and discovering security threats. However, these frameworks have some gaps regarding how they tackle the specific issues of IoT devices and communication protocols. For instance, while NIST 800-183 discusses the security of IoT devices in the context of federal information systems, it may not cover the entire set of threats about consumer IoT devices. Similarly, ISO/IEC 27001 and 27002 provide generic information security management best practices but lack detailed IoT-specific risk assessment frameworks. ETSI EN 303 645, even though it is optimised for the IoT, may not sufficiently address the complexity of new IoT technology and protocols coming into play. The IoT Security Maturity Model (SMM) by IIC provides a maturity-oriented framework but may fall short in terms of providing actionable mitigation of risks in the specific context of individual IoT environments.

3.1.2 Risk Registration and Documentation Practices

Risk documentation practices between these models reflect irregular tracking procedures and failure to adapt to the evolving IoT threat landscape.

NIST guidelines like SP 800-183 and SP 800-53 employ formally composed System Security Plans (SSPs), Risk Assessment Reports (RARs), and Plans of Action & Milestones (POA&Ms) for documenting and tracking risks, which do not incorporate IoT-taxonomical structures and real-time update features that are required in dynamic risk management. ISO/IEC 27001 entails detailed Risk Treatment Plans (RTPs) and Statements of Applicability (SoAs), which tend to become administratively laborious and out of context in specificity as applied to large-scale, distributed IoT environments. Procedural simplicity is provided by ETSI EN 303 645 compliance reports but does not address continuous monitoring or contextual specificity essential for sophisticated security governance. The IIC SMM's maturity-level documentation yields rapid security posture snapshots without operation threat intelligence integration or means of temporal tracking and prioritisation of remediation of risk. With all frameworks, a common shortcoming is the absence of automated and dynamic risk registries that will be able to scale dynamically with real-time IoT threat landscapes, hence limiting their application in comprehensive, enterprise-scale IoT risk governance. (SHACKELFORD, RUSSELL and HAUT, 2018) (Roy, 2020).

To address these gaps, our methodology, VECTOR, has an extensive risk analysis and risk register process. This would comprise the designation of assets, potential threats, and vulnerabilities related to IoT devices and communication protocols. The risk register would log those threats along with their probability and potential effect, ensuring a comprehensive understanding of the security environment.

3.2 Risk Evaluation

VECTOR's risk assessment process is founded upon the principles developed by existing frameworks but implements IoT-specific characteristics upon them.

While NIST 800-183 and 800-53 offer good risk assessment practices, these may not necessarily account for the unique nature of IoT devices, such as their constrained resources and diverse communication protocols. ISO/IEC 27001 and 27002 offer general risk assessment procedures but do not encompass specific IoT-based criteria. ETSI EN 303 645 and the IoT Security Maturity Model (SMM) by IIC are IoT-centric evaluations but may not cover all potential risk scenarios in great specificity like those involving redundant IoT devices which are not active but are idle, having useful data. VECTOR's risk assessment methodology involves a combination of qualitative and semi-quantitative assessments. This includes measurement of susceptibility to exploitation, operational impact of possible violations, and overall risk rating. The inclusion of IoT-specific risk elements such as protocol vulnerabilities, firmware security, and communication channels in VECTOR provides not only for the identification of risks but also for effective prioritization to facilitate effective risk mitigation approaches.

3.3 Risk Matrix

While NIST 800-183 and 800-53 include risk matrices that are broad and available for most information systems, they may not be inclusive of the unique risks specific to IoT devices. ISO/IEC 27001 and 27002 include general risk matrices but no detailed IoT-specific risk levels. ETSI EN 303 645 and IIC's IoT Security Maturity Model (SMM) include IoT-specific matrices but do not address all the possible scenarios of risks comprehensively.

Threat/Vulnerability	**Likelihood**	**Impact**	**Risk Level**
Lack of TLS in MQTT	High	Critical	Critical
Weak Wi-Fi Encryption	High	Critical	Critical
Sniffing and Pairing Attacks (Bluetooth/BLE)	High	High	Critical
Weak Authentication	High	High	Critical
Key Exchange Vulnerabilities (Zigbee/Z-Wave)	Medium	High	High
Outdated Firmware	Medium	High	High
NFC/RFID Cloning	Medium	Medium	Medium
Poor Encryption Standards	Low	Medium	Medium

Table 1: Risk Assessment

VECTOR's risk matrix categorises threats and vulnerabilities based on their exploitation potential, operational impact, and overall risk. The risk matrix is derived from other frameworks' broad risk categorisation but incorporates IoT-specific factors into it. VECTOR's

risk matrix, in this instance, categorises risks into high-critical, medium-high, medium, and low classes. It provides a specific and actionable method for risk management.

4. Risk Mitigation Strategies & Controls

4.1 Preventative Measures

Frameworks like NIST, ISO/IEC, and ETSI recommend good basics such as passwords, software updates, and data encryption. These guidelines, however, tend to be too generic and do not address the multiple vectors through which hackers target IoT devices. For instance, they rarely explain how the communication protocols of Bluetooth, Zigbee, or MQTT can be secured, or how device onboarding and decommissioning should be managed. The proposed framework fills these gaps by proposing rather concrete measures. It requires the implementation of the latest encryption standards (e.g., TLS 1.3 and WPA3), requires that every device has its unique credentials (not a default password), and requires regular rotation of security keys for protocols like Zigbee and Z-Wave. VECTOR also requires that all firmware updates are signed and verified before installation and that devices use secure boot to protect against tampering. Along with this, VECTOR encourages organizations to segment their networks, thereby IOT devices are isolated from sensitive systems, and to buy devices only from those vendors who commit to offering regular security updates and open vulnerability reporting. These measures go beyond what is required by most frameworks, making security both more feasible and effective for real-world IoT environments.

4.2 Detective Measures

While existing frameworks do discuss monitoring and routine security audits, they do not specifically require continuous, real-time threat detection. VECTOR addresses this by recommending that organizations use network IDS, protocol analysers, and centralised logging to detect suspicious activity in real-time. For example, the network traffic can be monitored for unusual patterns through tools like Wireshark, while attacks on Bluetooth and Zigbee-based devices can be uncovered with the assistance of Bettercap. VECTOR also suggests implementing Security Information and Event Management (SIEM) systems to collect and analyse logs from all the devices, so that coordinated attacks or multiple intrusion attempts become more apparent. Periodic vulnerability scanning with the help of tools like Binwalk (for firmware) and automatic notification of abnormal device behaviour is also part of VECTOR's plan.

4.3 Security Controls for Dormant/Idle IoT Devices

The security of redundant IoT devices is generally considered trivial and not a priority in traditional frameworks. These guidelines do not typically tackle active device management, constant patching, and network segmentation to minimise attack surfaces, proposing baseline controls like disabling unused ports, encryption, and ensuring devices are included in vulnerability scanning, but might not cover in-depth or proactive actions for devices that

are powered on but not actively used. As such, idle devices can be soft targets for attackers, especially if they are left unattended or on legacy firmware. The VECTOR framework fills these gaps by introducing controls and monitoring that are specifically tailored for idle devices. Beyond standard hardening and segmentation, VECTOR recommends automated idleness detection, with a policy that can trigger network quarantine or even secure decommissioning if a device has been idle for some prolonged time.

It also demands constant vulnerability scanning even for not frequently used devices and mandates that inactive devices receive the same level of firmware and credential management as active devices.

In addition, VECTOR advocates protocol-specific monitoring and energy-efficient security mechanisms, ensuring even low-power, idle devices are not excluded. This active and multi-layered approach removes the threat that dormant devices are vulnerable points in the IoT landscape, an opening most existing frameworks overlook.

4.4 Residual Risk, Risk Acceptance & Transfer

Frameworks require organisations to make risk assessments and determine their risk appetite, classifying devices and controls by potential impact according to models like the CIA triad (Confidentiality, Integrity, Availability). They support the documentation of residual risks and risk acceptance decisions, but they typically provide minimal practical guidance on risk transfer (e.g., outsourcing or insurance), or tools for supporting judgments of the effectiveness of such measures. VECTOR seeks to close these gaps by providing more practical guidance and more specific criteria for risk transfer and acceptance.

5. Conceptualisation of the VECTOR Framework

VECTOR is designed and developed following a structured approach, integrating technical insight, policy compliance and threat intelligence. This section outlines the key design phases and rationale behind the proposed framework.

5.1 Framework Layers

VECTOR is structured into three core security layers, each with its own set of goals and objectives:

1. Manufacturing
2. Protocol
3. Data Storage

5.2 The Framework Design

VECTOR is explicitly designed to secure the data communication which happens at the protocol level within consumer IoT ecosystems from an end-to-end perspective. It addresses critical vulnerabilities across the manufacturing, data transfer/protocol communication, and

data storage layers. The visualisation below represents this layered and continuous control structure.

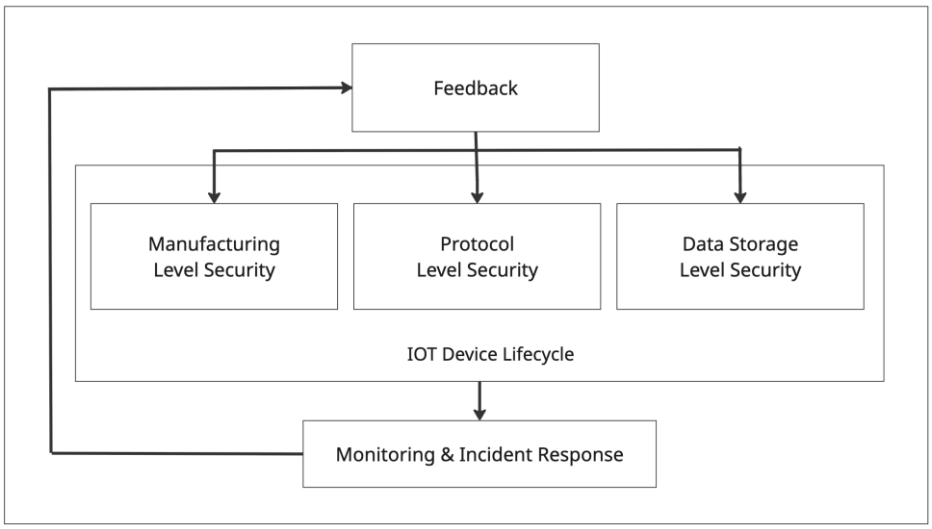

Fig: 1. VECTOR Overview

This diagram provides a high-level overview of the IoT device security lifecycle, emphasizing a layered and cyclical approach to maintaining security. The framework operates across four key phases of the IoT device lifecycle: Provisioning, Onboarding, Decommissioning & Monitoring. Each phase corresponds to a dedicated VECTOR security layer, ensuring that devices are protected from manufacture through decommissioning. This ensures the threats are remediated at the point of their origin.

Each security domain addresses specific vulnerabilities: manufacturing security focuses on hardware integrity and secure provisioning, protocol security ensures safe communication through encryption and key management, and data storage security protects stored data from unauthorised access or tampering.

At the core of the framework is Monitoring & Incident Response, which serves as the operational defence mechanism to detect threats and respond to security incidents in real time. Importantly, the architecture is reinforced by a Feedback mechanism that connects all layers of security. This feedback loop enables continuous improvement by feeding insights from monitoring and incident analysis back into the security layers to update defences, patch vulnerabilities, and adapt to emerging threats. This cyclical nature ensures the system evolves, maintaining resilience throughout the device's lifecycle.

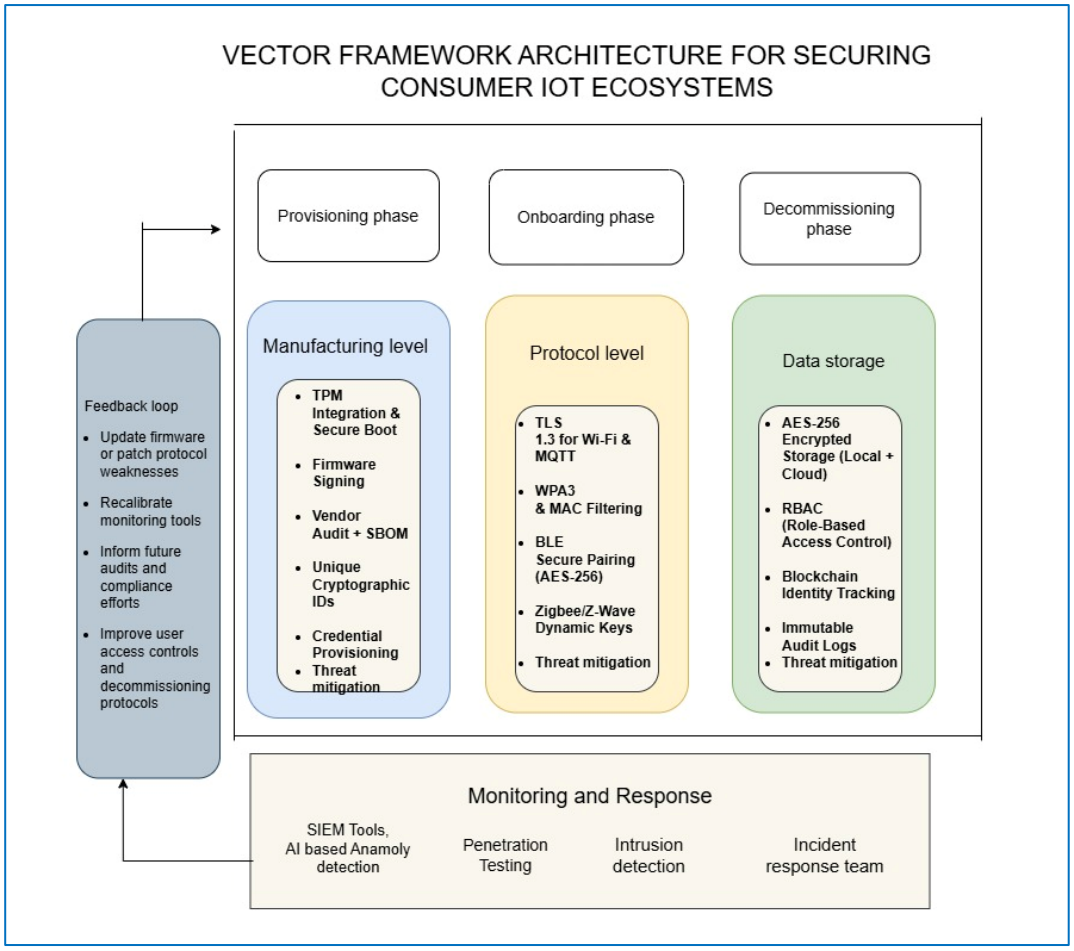

Fig: 2. VECTOR Framework

5.2.1 The Provisioning Phase

The provisioning phase is the critical starting point in the VECTOR framework, setting the foundation for a secure consumer IoT ecosystem. It is a manufacturing-level security established through a combination of hardware, software, and supply chain controls; all integrated from the earliest stages of device production (Obaidat et al., 2020). The VECTOR framework makes sure that manufacturing security comes from using hardware, software and supply chain controls which are all present from when the device is first made. This starts by adding Trusted Platform Modules (TPMs) and putting into place a secure boot, making it possible for only the correct firmware to function on the device. Every device is assigned a set of unique credentials, and a cryptographic identifier and firmware is also signed by default which keeps default or hardcoded passwords from posing a threat. Vendors are vetted carefully and an SBOM helps to make sure every hardware and software part is clear in the system. They reduce the chance that counterfeit or unsafe parts are added to the product.

All important actions related to security such as credential setup, firmware signing and sourcing of components, are recorded in unchangeable audit logs, making it easy to monitor and stay compliant. Secure firmware updates are included which guarantees that devices can

be updated properly while in use. When the device reaches the end of its use, cleaning up information with certified procedures is performed to prevent any data breaches.

An IoT device adopted under this approach is verified by firmware signed by the manufacturer, has unique data and its record of origin can be checked; additionally, it can be rendered securely useless when you want to get rid of it. By putting these controls in manufacturing, VECTOR identifies risks that other ways might overlook, ensuring solid IoT device security.

5.2.2 The Onboarding Phase

This paramount phase is associated with the protocol level, with its primary objective to secure the foundation for all communications occurring within the IoT ecosystem. The phase ensures that all devices connecting to the network use strong, industry-standard security protocols over their communication channels and must be configured to use the most secure communication protocols possible. For example, Wi-Fi modules are configured to use strictly WPA3 encryption, an improvement from prior standards such as WPA2. WPA3 also provides features such as individualised data encryption and strong protection against attacks, which are common vulnerabilities in wireless communication.

Bluetooth/BLE connections are equally secure upon onboarding. Devices must make use of AES-256 encryption and pairing protocols for authentication. This would help to deny unauthorised access, and protection against sniffing and man-in-the-middle attacks which arise through legacy pairing or pairing without authentication. This ensures that the data exchanged over Bluetooth channels stays confidential and remains untampered. Protocols such as MQTT are optionally used for lightweight messaging in an IoT environment, embarking upon enforced supplements of TLS 1.3 tunnels under mutual authentication during the onboarding phase. This ensures that all the traffic in MQTT passes through encryption and authentication, hence eliminating any incidence of eavesdropping or putting at risk any device that is not trusted to take part in message exchanges.

Zigbee and Z-Wave devices in mesh network configurations are subject to dynamic key rotation mechanisms. It provides countermeasures against possible mesh network hijacking attempts, which, if static keys or keys reused among multiple devices, would otherwise be possible. By rotating keys at a regular interval, this approach ensures that even when a key is compromised, it is only for a very limited time, thereby securing the mesh network. During onboarding, NFC-based and RFID-based systems are also included; these use challenge-response authentication and encrypted verification of the UIDs to ensure cloning and unauthorised use are eliminated.

Additionally, during onboarding, apart from securing communication channels, the immutable audit logs and the tracking of device identity are also secured. Such controls give a full account of what devices do and how they change, thereby attributing responsibility and allowing forensic analysis should a security incident occur. The IT security teams, the network engineers, and the device integrators are responsible for installing and maintaining those controls, working hand in hand to ensure that every device is up to par with their very strict set of security requirements before it is admitted into the ecosystem.

Addressing the risks associated with the onboarding phase early in a device lifecycle, helps to secure the core network and all communication channels adequately. This strategy guarantees that the whole IoT environment runs under a framework of trust and responsibility in addition to preventing typical risks. Knowing that every gadget has been carefully screened and set to maintain the best standards of protocol communication security, companies can thus boldly scale their IoT installations.

5.2.3 The Decommissioning Phase

In the Decommissioning stage, corresponding to the data storage level, the focus is on ensure that all data remains secure when an IoT device is being retire or is moved to the dormant mode. It is important to ensure that no unauthorised access to sensitive information, irrespective of onsite or cloud storage, is established. Implementing AES-256 encryption for the data, ensuring that even if the possession of the device is compromised, the information remains inaccessible without permission. Moreover, role-based access control (RBAC) is required to avoid data access strictly to legitimate stakeholders, therefore minimising the data exposure risk vector.

Wiping the activities and data stored on a redundant device falls in compliance with the GDPR's Right to be Forgotten. It must be carried out by using trusted tools that guarantee the complete and irreversible destruction of all data. This process is supplemented by credential revocation, wherein all access tokens and device-specific credentials are revoked to eliminate the possibility of unauthorised reuse or exploitation. The implementation of the dormant protocol can ensure that the device goes into the dormant mode from the active mode after 30 days of constant inactivity. These tasks are often handled by compliance officers, security staff, and data administrators to ensure that each step is within organization policy and regulatory requirements. To further ensure maximum data integrity and auditability, immutable storage technologies such as Write Once Read Many (WORM) systems and blockchain-based ledger protocols are employed for log files and sensitive data. Such technologies provide tamper-proof records that can be used for forensic analysis or compliance audits and whereby the history of device activities and data management remains transparent and reliable.

Furthermore, the decommissioning phase also addresses the risk of redundant IoT devices, which are exposed to exploitation. WPA3 upgrade of Wi-Fi, which calls for AES-256 encryption of Bluetooth traffic, and dynamic key rotation of Zigbee and Z-Wave protocols are significant measures to take to ensure that security remains intact even when devices are on the verge of end-of-life. The Decommissioning stage also involves regular firmware updates and legacy protocol disabling to remove potential attack channels. Public Key Infrastructure (PKI) is applied for device connection authentication, reducing the risk of unauthorised access. With strong access controls and secure data erasure mechanisms, these integrated with the above, organizations can securely decommission IoT devices without the threat of data leakage and device re-exploitation.

5.2.4 The Monitoring Phase

The Monitoring phase in the VECTOR framework lies underneath the lifecycle layers, serving as a critical component in the system for real-time threat detection and risk management. The primary purpose of this phase is to continuously observe device and network behaviour, promptly identify anomalies, and ensure rapid, coordinated responses to security incidents. It plays a pivotal role in consumer IoT environments, where new vulnerabilities can emerge rapidly and device diversity is high.

How surveillance is performed:

Security Information and Event Management (SIEM) systems are used to consolidate logs; spot unusual patterns and implement AI to detect anomalies. New vulnerabilities are regularly sought out so when a threat or anomaly is identified, the process calls for isolation of the device, an investigation and quick software update application. All these activities are outlined to confirm that the company is following rules and requirements.

What is included in monitoring:

1. SIEM Tools & Anomaly Detection: Gather and investigate logs to detect any strange actions coming from IoT devices or different network sections.
2. Use Deep Learning Anomaly Detection to find small, unfamiliar behaviours as soon as they begin.
3. Penetration Testing: Considerately simulate security breaches to locate weaknesses in how the devices are set up and work.
4. Incident Response Team: People who are always prepared to respond and fix incidents.

At this point, SOC analysts, IT security teams, compliance officers and third-party auditors all work together. Feedback from monitoring is put into a cycle so that the firmware, protocols, and restrictions can be updated all the time. This lets the VECTOR framework stay resilient and adjust to new dangers and makes sure it stays compliant with support from Binwalk, QEMU, Bettercap, Hydra and OpenSSL and by following standards like NIS2, ISO/IEC 27030 and GDPR.

The feedback loop in the VECTOR Framework plays a crucial role in strengthening the security posture across the IoT device lifecycle. It involves continuously updating firmware and patching protocol-level weaknesses identified during the monitoring phase. Because of this loop, it’s possible to periodically update monitoring equipment in response to new risks. Information gathered while monitoring shapes upcoming audits and compliance projects to help meet regulations. The feedback system will make it possible to adjust user access and improve decommissioning processes and this helps the security system change as needed to protect against real threats.

5.3 Threat-to-Control Mapping

The VECTOR framework organises main threats in consumer IoT devices and matches them to recommended security steps starting from device setup. As an example, Bluetooth Low Energy (BLE) sniffing is prevented by requiring encryption for pairing and using AES-256 for communication. MQTT session hijacking risks are decreased when you use TLS 1.3 and establish mutual authentication for encryption and data confirmation. Secure boot, OTA

updates powered by signatures and firmware tested using emulation help to handle risky firmware injection. VECTOR reduces the threat of shadow data leaks by combining encryption and access controls that limit unapproved users from seeing sensitive data. An identity registry on the blockchain and secure wipe procedures are added to eliminate the chance someone could reuse the device after purchase. Because this uses protocols to identify and treat threats, each threat triggers a specific action, capping the openings left by earlier guidelines and securing all parts of consumer IoT.

5.3.1 Protocol-Centric IoT Risk Register

The table below demonstrates the proposed Protocol-Centric IoT Risk Register. It highlights each risk, flaws and its impacts concerning key protocols namely Wi-Fi, Bluetooth/BLE, MQTT, Zigbee/Z-Wave and NFC/RFID. Contrary to regular risk registers, this table includes protocol problems such as relatively weak encryption, unsecure ways to pair or the absence of mutual authentication and links each problem to suitable controls and methods to minimise it. The register allows risks to be addressed and prioritised based on the lifecycle stage, so that the VECTOR framework can target and resolve the key and unnoticed problems that arise in consumer IoT systems.

Field	MQTT	Bluetooth/BLE	Zigbee/Z-Wave	NFC/RFID	Wi-Fi
Process Owner	IoT Security Team	IoT Security Team	IoT Security Team	IoT Security Team	IoT Security Team
Asset Affected	Smart Home Devices	Bluetooth Devices	Zigbee/Z-Wave Devices	NFC/RFID Devices	Wi-Fi Connected IoT
Risk Description	Data interception via insecure MQTT protocol	Unauthorised access from weak pairing/authentication	Command hijacking due to weak key exchange protocols	Device cloning via lack of cryptographic tag-device binding	Brute-force attacks on WPA2-PSK; risk of unauthorised device access
Threat	MITM/interception	Device hijacking	Command injection	Cloning/fraud	Unauthorised access
Vulnerability	MQTT without TLS encryption or topic access controls	No mutual authentication during Bluetooth/BLE pairing	Insecure key exchange in Zigbee/Z-Wave mesh networks	No cryptographic binding between NFC/RFID tags and readers	Use of WPA2-PSK instead of WPA3-SAE
Inherent Risk Likelihood	High	High	High	Medium	High
Inherent Risk Impact	High	Severe	High	Moderate	Critical
Risk Owner	IoT Security Lead	IoT Security Lead	IoT Security Lead	IoT Security Lead	IoT Security Lead
Risk Level	High	High	High	Medium	High
Risk Score	16	20	16	9	20
Risk Treatment Plan	Enforce TLS 1.3 and mutual auth for MQTT;	Enable BLE Secure Connections;	Implement ECDH key exchange and regular key rotation	Deploy AES-128 challenge-response authentication	Upgrade to WPA3-SAE and enforce Protected

	restrict topic access	enforce OOB pairing			Management Frames
Target Date	30/06/2025	30/06/2025	15/07/2025	15/07/2025	31/07/2025
Control Name	Protocol Hardening	BLE Secure Pairing Enforcement	Zigbee/Z-Wave Key Management	NFC/RFID Crypto Binding	Wi-Fi Security Upgrade
Control Description	Update MQTT stack to require TLS 1.3, mutual certs, and topic ACLs	Configure BLE stack for Secure Connections and OOB pairing	Enforce ECDH-256 key exchange and automate mesh key rotation	Implement dynamic AES-128 challenge-response protocol for all NFC/RFID interactions	Transition all IoT devices to WPA3-SAE and enable PMF
Control Progress	In Progress	Planned	In Progress	Planned	Not Started
Residual Risk	Medium	Low	Low	Low	Medium
Overall Score	12	8	9	6	12

Table 2: Example Risk Register

5.3.2 Implementation and Monitoring

The framework follows a phased, role-defined approach that supports layered security integration across the IoT device lifecycle. Rather than prescribing a rigid template, VECTOR provides a structured yet adaptable model that aligns security controls with device production, communication, data handling, and monitoring processes with its primary focus on protocol communication.

Phase 1: Planning and Preparation

Identification of stakeholders is the most critical task in the framework's implementation. It is necessary to determine the level of security required for the data the device transmits. The team responsible comprises of security engineers for embedded protection, network administrators for protocol-level configuration, compliance lead for regulatory conformance, and software developers for integration at the firmware and app levels.

Following this the existing infrastructure should be analysed to identify the security level and vulnerabilities which may lay within. This includes checking how firmware is deployed, device communication, encryption and how access is controlled. As a result of this assessment, VECTOR’s controls are applied to each stage of the lifecycle.

At the same time, it is important to set up asset registers, making basic security policies and designing templates for handling incidents during the implementation process. They provide the structure needed for VECTOR to be carried out in a consistent and policy-compliant way.

Phase 2: Technical Integration

During the technical integration phase, VECTOR’s controls are added to the three main security layers, starting with manufacturing. This means using Trusted Platform Modules

(TPMs) as trust anchors, giving every device a unique cryptographic identifier and setting up secure firmware signing and verification processes with trusted tools. A Software Bill of Materials (SBOM) helps maintain the integrity of the supply chain by revealing all the components used. It is important for device manufacturers to work with security developers, using secure firmware repositories and immutable audit logs.

At this level, administrators must set up wireless modules such as Wi-Fi, Bluetooth, Zigbee and MQTT to meet the latest security standards. Mutual authentication, changing keys regularly and requiring TLS or similar encryption methods help to strengthen protocols. They are put in place by using encryption libraries, systems for providing credentials and secure gateways that block unauthorised access.

Data that is not being used is encrypted with standard algorithms and access to it is controlled by Role-Based Access Control (RBAC). Lifecycle controls involve removing access to devices and securely erasing data to ensure proper decommissioning. At this stage, cloud access management and automated deprovisioning are used to prevent retired devices from being used by attackers.

Phase 3: Monitoring and Response

It is important to keep monitoring the system after it has been deployed to ensure it remains resilient. SIEM systems are put in place to gather, link and study logs from devices, servers and endpoints. In addition, intrusion detection and prevention systems (IDS/IPS) are set up at important network points to detect and prevent suspicious activities or known attacks. In large environments, cloud-based monitoring services help you see what is happening with remote assets and their connections with other parts of the system.

To improve incident response, organisations create playbooks that outline the actions to take during a breach or unusual event. These steps are detection, analysing the impact, isolating the threat, investigating it and deploying a patch. Security operations teams oversee these actions to make sure containment and recovery happen quickly. In addition, organisations should set up vulnerability disclosure programs and follow response protocols that are in line with industry standards such as those outlined by the NIS2 Directive.

Phase 4: Review, Feedback, and Improvement

After VECTOR is running, a continuous process of feedback is put in place. The information from monitoring, incident reports and threat intelligence is used to update and improve security settings, firmware, onboarding and access control policies. This allows VECTOR to respond to new threats and technical weaknesses.

At the same time, organisations keep their documentation current, including risk registers, audit logs and compliance reports. Security policies are regularly checked and updated based on new lessons, industry standards and changes in regulations. This last step maintains the quality of the implementation and allows VECTOR to adjust to new challenges in IoT security.

5.3.3 Assessment and Validation of VECTOR

VECTOR framework, as presented in this report, is a proposed model and has not yet been tested in practical, real-world deployments. The framework is the result of detailed research, analysis, and critical study of existing IoT security frameworks carefully identifying their strengths as well as their limitations. Determining where current security standards are lacking, mainly in the protocols and devices that sit in a dormant or inactive mode, VECTOR is designed to address these and give a better way to protect the IoT for everyone.

6. Conclusion and Recommendations

6.1 Summary

The framework, VECTOR, is implemented against the four proposed phases across the consumer IoT device lifecycle, namely, provisioning, onboarding, decommissioning, and monitoring. The layered approach combines preventative, detective, and corrective controls, focuses on securing the protocol used to communicate data which enables the convenient detection of threats that are recognised and mitigated at the point of interception. To instil security into the IoT devices right from the designing of the device, the framework enforces adequate usage of security strategies such as cryptographic techniques, access control, and using secure configurations.

VECTOR proposes an actionable and compliant framework aimed towards consumer IoT devices with policies that introducing relevant controls aligned with standards such as the EU Cyber Resilience Act, the NIST Special Publication 800 series, and the ISO/IEC 27000 series. The framework further supports the practical verification technique informed by tools so that organisations can relate technical controls with real threat scenarios. This framework is suitable for dynamic and scalable IoT environments, as it is feedback-driven, with a view to reinforcing long-term resilience.

6.2 Recommendations

Organisations must tighten the security of their IoT using the most advanced encryption such as WPA3 for air communication and AES-256 to encrypt data at rest in devices. PKI, X.509 certificates and OAuth 2.0 should be applied for devices and services to exchange mutual trust. Briefly, on the one hand, companies are expected to follow standards like ISO/IEC 27030, GDPR and NIST SP 800-183 in data governance, end-user privacy and supply chain openness. AI can enhance security guarantee by integrating anomaly detection systems with Intrusion Detection and Prevention Systems (IDS/IPS). It offers real-time monitoring and instantaneous threat categorisation, so a strong response is possible for incidents. It is good to engage manufacturers in developing security policies, to simplify vulnerability disclosure and to ensure that safe routines are adopted at every step of IoT product designing.

6.3 Future Work

The next phase should focus on the testing and deployment of the framework which was not carried out within the scope of this project. Research and development of SENTINEL (Secure Encrypted Network Transmission for IoT with Next-gen Encryption Layers), which is an IoT communication protocol built from scratch, aim to provide a secure, lightweight, and scalable backbone for modern IoT ecosystems. The protocol will be end-to-end encrypted using TLS 1.3 or DTLS 1.3 with AES-256 for data integrity and confidentiality, and mutual authentication using PKI-based credentials. It will be low-power device optimised and secured against common attack vectors like man-in-the-middle, replay, sniffing, and key compromise scenarios. SENTINEL will also be carried over multi-transport channels like Wi-Fi, Zigbee, Z-Wave, Bluetooth LE, NFC, LoRaWAN, and 5G IoT. It will prioritise low-latency and lightweight communications via binary serialisation techniques, incorporate AI-driven anomaly detection and self-healing, and operate under a Zero Trust model with re-authentication for every session. This next-generation protocol is an ideal chance for secure, scalable, and policy-compliant IoT connectivity.

References

Nthatisi Hlapisi. (2023, July 16). Vulnerabilities and Attacks on Bluetooth LE Devices—Reviewing Recent Info. Allaboutcircuits.com; All About Circuits. https://www.allaboutcircuits.com/technical-articles/vulnerabilities-and-attacks-on-bluetooth-le-devicesreviewing-recent-info/

Antonio Francesco Gentile, Davide Macrì, Domenico Luca Carnì, Greco, E. and Lamonaca, F. (2024). A Performance Analysis of Security Protocols for Distributed Measurement Systems Based on Internet of Things with Constrained Hardware and Open Source Infrastructures. Sensors, [online] 24(9), pp. 2781–2781. doi:https://doi.org/10.3390/s24092781

Kim, K., Cho, K., Lim, J., Jung, Y. H., Sung, M. S., Kim, S. B., & Kim, H. K. (2020). What's your protocol: Vulnerabilities and security threats related to Z-Wave protocol. *Pervasive and Mobile Computing*, *66*, 101211. https://doi.org/10.1016/j.pmcj.2020.101211

Palamà, I., Amici, A., Bellicini, G., Gringoli, F., Pedretti, F. and Bianchi, G. (2023). Attacks and vulnerabilities of Wi-Fi Enterprise networks: User security awareness assessment through credential stealing attack experiments. *Computer Communications*, [online] 212, pp.129–140. doi:https://doi.org/10.1016/j.comcom.2023.09.031

Obaidat, M.A., Obeidat, S., Holst, J., Al Hayajneh, A. and Brown, J. (2020). A Comprehensive and Systematic Survey on the Internet of Things: Security and Privacy Challenges, Security Frameworks, Enabling Technologies, Threats, Vulnerabilities and Countermeasures *Computers*, 9(2), p.44. doi:https://doi.org/10.3390/computers9020044.

Shahid Ul Haq, Singh, Y., Sharma, A., Gupta, R., & Gupta, D. (2023). A survey on IoT & embedded device firmware security: architecture, extraction techniques, and vulnerability

analysis frameworks. *Discover Internet of Things*, *3*(1). https://doi.org/10.1007/s43926-023-00045-2

Dalal Abdumohsin Hammood, Rahim, H. A., Alkhayyat, A., Ahmad, R. B., Muzammil Jusoh, & Abbasi, Q. H. (2019). Non-Cooperative Game Theory Approach for Cognitive Cooperative Communication in WBAN. *Enlighten: Publications (the University of Glasgow)*, 1–5. https://doi.org/10.1109/icsima47653.2019.9057305

Wang, W., Jadhav, N., Vohs, P., Hughes, N., Mazumder, M., & Gil, S. (2022). Active Rendesvous for Multi-robot Pose Graph Optimisation Using Sensing over Wi-Fi. *Springer Proceedings in Advanced Robotics*, 832–849. https://doi.org/10.1007/978-3-030-95459-8_51

Ramakrishna, D., & Shaik, M. A. (2024). A Holistic analysis of Cryptographic Algorithms: Evaluating Security, Efficiency, and Future Challenges. IEEE Access, 1–1. https://doi.org/10.1109/access.2024.3518533

Vaccari, I., Cambiaso, E., & Aiello, M. (2017). Remotely Exploiting AT Command Attacks on ZigBee Networks. Security and Communication Networks, 2017, 1–9. https://doi.org/10.1155/2017/1723658

Yisa, V., Baba, M., & Olaniyi, E. (2016). A Review of Top Open-Source Password Cracking Tools. https://ceur-ws.org/Vol-1830/Paper89.pdf

https://webbylab.com/blog/iot-in-consumer-electronics-market/

Appendix: Terminology

1. NIST SP 800-183
A publication from the National Institute of Standards and Technology (NIST) that provides guidelines for establishing and securing Internet of Things (IoT) ecosystems, with a focus on risk identification related to device heterogeneity and connectivity.

2. NIST SP 800-53
A comprehensive NIST framework outlining security and privacy controls for federal information systems and organisations, covering both adversarial and non-adversarial risks.

3. NIST SP 800-30
A NIST guide for conducting risk assessments, providing methodologies for identifying, estimating, and evaluating risks to organisational operations and assets.

4. System Security Plan (SSP)
A formal document required by NIST frameworks that describes the security requirements and controls in place for an information system.

5. Risk Assessment Report (RAR)
A report detailing the findings of a risk assessment, including identified threats, vulnerabilities, and potential impacts.

6. Plan of Action & Milestones (POA&M)
A management tool used by organisations to track the progress of risk mitigation activities and the resolution of identified security weaknesses.

7. ISO/IEC 27001
An international standard for information security management systems (ISMS), specifying requirements for establishing, implementing, maintaining, and continually improving an ISMS.

8. ISO/IEC 27005
A supporting standard to ISO/IEC 27001, providing guidelines for information security on risk management, including risk assessment and treatment processes.

9. Risk Treatment Plan (RTP)
A document required by ISO/IEC 27001 that outlines the measures an organisation will take to address identified information security risks.

10. Statement of Applicability (SoA)
A document that specifies which controls from ISO/IEC 27001 are applicable to the organisation and provides justification for their inclusion or exclusion.

11. ETSI EN 303 645
A European standard developed by the European Telecommunications Standards Institute (ETSI) specifying cybersecurity provisions for consumer IoT devices, focusing on baseline security requirements such as password management and vulnerability disclosure.

12. Industrial Internet Consortium (IIC) Security Maturity Model (SMM)
A framework developed by the IIC for assessing the maturity of an organisation's IoT security practices across six security domains using graduated maturity indicators.

13. Asset-Based Risk Assessment
A risk assessment approach that focuses on identifying and evaluating risks associated with specific organisational assets, such as devices, data, or processes.

14. Adversarial and Non-Adversarial Risks
Adversarial risks refer to threats posed by intentional, malicious actors (e.g., hackers), while non-adversarial risks arise from accidental or environmental factors (e.g., system failures, natural disasters).

15. Edge Computing
A distributed computing paradigm that brings computation and data storage closer to the location where it is needed, often at or near IoT devices, to improve response times and save bandwidth.

16. Operational Technology (OT) Convergence
The integration of information technology (IT) systems with operational technology (OT) systems, such as industrial control systems, within IoT environments.

17. Sero-Day Vulnerabilities
Previously unknown security flaws in software or hardware that are exploited by attackers before the vendor becomes aware and issues a fix.

18. Threat Taxonomy
A structured classification system for organizing and categorizing different types of threats and attack vectors.

19. Maturity Indicators
Metrics or benchmarks used to assess the level of development or sophistication of an organization's security practices within a maturity model framework.

20. Compliance Reports
Documentation required by certain standards (e.g., ETSI EN 303 645) to demonstrate that an organization's products or processes meet specified security requirements.

21. Threat Intelligence
Information about existing or emerging threats that can help organizations anticipate, prevent, or respond to cybersecurity incidents.

22. Dynamic Risk Registry
A continuously updated repository or system for tracking and managing risks in real time, particularly useful in rapidly changing environments such as IoT.

23. Internet of Things (IoT)
A network of interconnected physical devices that collect, exchange, and process data using embedded sensors, software, and other technologies.

24. Industrial IoT (IIoT)
A subset of IoT focused on industrial applications, such as manufacturing, energy, and transportation, where connected devices and systems are used to optimise operations and improve safety.